

MÓDULO 3 · DOSSIER 11

Claves de sesión

Una sesión segura une autenticación, establecimiento, contexto, separación, AEAD, rotación y destrucción.

Material elaborado por el profesor Sergio Gevatschnaider

Fuente curricular verificable · SHA-256 7e4a63bcb736

Contenido

Propósito	3
Resultados de aprendizaje	3
Núcleo teórico	3
Separación y contexto	3
Secreto hacia adelante	3
Profundización y criterio profesional	3
Caso de análisis	4
Entrega esperada	4
Riesgos y errores frecuentes	4
Actividades de dominio	4
Lista de comprobación	4
Referencias seleccionadas	4

Propósito

Una sesión segura une autenticación, establecimiento, contexto, separación, AEAD, rotación y destrucción.

Resultados de aprendizaje

1. construir una sesión híbrida.
2. usar HKDF con contexto.
3. definir condiciones de secreto hacia adelante.

Núcleo teórico

Una clave de sesión se limita a una conexión, archivo, dirección o intercambio. Que sea de corta duración reduce exposición y facilita rotación, pero no implica automáticamente secreto hacia adelante.

El patrón moderno es:

```
autenticación de claves públicas
-> transporte, acuerdo o KEM
-> KDF con contexto
-> claves separadas por dirección y propósito
-> AEAD con nonce y AAD
-> rotación y destrucción
```

Ejemplos:

```
ECDH -> HKDF -> AES-GCM
X25519 -> HKDF -> ChaCha20-Poly1305
ML-KEM -> KDF -> AEAD
RSA-OAEP -> clave aleatoria transportada -> AEAD
```

ECDH sin autenticación es vulnerable a man-in-the-middle. La identidad se establece mediante certificados, firmas, huellas verificadas, PSK u otro canal autenticado.

Separación y contexto

HKDF no “fortalece” una contraseña. Su función normal es extraer y expandir material de alta entropía. Los campos de contexto deben vincular protocolo, versión, roles, transcript y propósito. Deben derivarse claves diferentes para cifrar, autenticar, exportar o cada dirección del canal.

Secreto hacia adelante

Existe cuando comprometer una clave de identidad de largo plazo no permite recuperar sesiones pasadas. Requiere un establecimiento efímero autenticado y que los secretos efímeros ya no existan al momento del compromiso. Guardar el secreto efímero, reutilizarlo indefinidamente o transportar claves mediante RSA estático cambia esa conclusión.

Profundización y criterio profesional

El secreto compartido bruto no debe utilizarse directamente como todas las claves. HKDF extrae y expande material de alta entropía; sus etiquetas deben vincular versión, roles, transcript, dirección y propósito. Emisor y receptor derivan claves distintas para evitar reflexión y uso cruzado.

Los números de secuencia pueden participar en nonces y control de repetición. El protocolo debe especificar límites de mensajes, renovación, cierre, errores y eliminación. Una clave de sesión corta limita exposición, pero no garantiza por sí sola secreto hacia adelante.

Etap	Control	Falla evitada
Autenticación	Certificado, firma, PSK o huella	MITM

Etapa	Control	Falla evitada
Establecimiento	Transporte, acuerdo o KEM	Secreto compartido incorrecto
Derivación	HKDF y contexto	Uso cruzado
Datos	AEAD y secuencia	Alteración y repetición

Caso de análisis

Diseñe una sesión bidireccional con X25519, transcript firmado, HKDF y ChaCha20-Poly1305. Defina etiquetas, claves por dirección, nonces, rotación y destrucción.

Entrega esperada

Documento activos, actores, propiedad, parámetros, flujo, condición de fallo y decisión recomendada. Separe siempre la garantía criptográfica de la garantía operativa.

Riesgos y errores frecuentes

- usar el secreto ECDH directamente.
- derivar ambos sentidos con la misma etiqueta.
- guardar secretos efímeros indefinidamente.

Actividades de dominio

1. ¿Qué debe entrar al contexto de HKDF?
2. ¿Qué condiciones dan secreto hacia adelante?
3. ¿Cómo se evita repetir nonces entre emisores?

Lista de comprobación

- Puedo definir la propiedad y el adversario.
- Puedo explicar parámetros, límites y supuestos.
- Puedo detectar al menos tres configuraciones inseguras.
- Puedo justificar una decisión de arquitectura.
- Puedo relacionar el tema con una norma o especificación primaria.

Referencias seleccionadas

1. RFC 5869: HKDF - <https://www.rfc-editor.org/rfc/rfc5869>
2. RFC 8446: TLS 1.3 - <https://www.rfc-editor.org/rfc/rfc8446>